

# Universitas Warmadewa — Web Security Review (Quick)

**Tanggal:** 18 Juni 2026

**Reviewer:** Afiq Andico, mahasiswa Sistem Informasi, STIKOM Bali

**Target:** <https://www.warmadewa.ac.id/>

**Metode:** Static analysis saja — HTTP header inspection, HTML inspection

**Cakupan:** Public surface only

## Ringkasan Eksekutif

Warmadewa website berjalan di **Laravel** framework (PHP) di belakang **Cloudflare** dengan **LiteSpeed** sebagai origin server. **Secara keseluruhan lebih aman dari UNUD** karena:

- ✓ Laravel punya CSRF protection built-in (XSRF-TOKEN cookie visible)
- ✓ Cookie flags proper (Secure, SameSite, HttpOnly)
- ✓ Tidak ada user enumeration (bukan WordPress)
- ✓ Cloudflare WAF di front
- ✗ Tapi missing security headers standard (CSP, HSTS, dll)

| Severity | Count | Items                                                                                      |
|----------|-------|--------------------------------------------------------------------------------------------|
| Medium   | 3     | Missing HSTS, CSP, X-Frame-Options                                                         |
| Low      | 0     | (no major issues found)                                                                    |
| Info     | 1     | Custom cookie ( <code>zesXZsnTwkKIShM7GTNeC6as5KHPUkywfn80QhYe</code> ) — perlu verifikasi |

**Risk level: RENDAH** — tidak ada exploitable vulnerability dari public surface yang aku verify. Defense-in-depth perlu diperkuat.

## 1. Tech Stack Terdeteksi

```
Laravel (PHP framework) - version not exposed in headers
LiteSpeed (web server, behind Cloudflare)
Cloudflare CDN + WAF (active)
jQuery + Bootstrap (frontend)
Google Tag Manager (analytics)
```

**Laravel** = framework PHP modern, security-aware by default (CSRF, validation, escaping built-in). Ini positif.

## 2. Security Headers Analysis

**Bukti reproduksi:**

```
curl -sI https://www.warmadewa.ac.id/
```

**Hasil:**

| Header                        | Status    | Catatan                                    |
|-------------------------------|-----------|--------------------------------------------|
| Server: cloudflare            | ✓         | Cloudflare menyembunyikan origin server    |
| X-Turbo-Charged-By: LiteSpeed | (info)    | LiteSpeed visible (di belakang Cloudflare) |
| Strict-Transport-Security     | ✗ MISSING | HTTPS-only enforcement                     |
| Content-Security-Policy       | ✗ MISSING | XSS defense in depth                       |
| X-Frame-Options               | ✗ MISSING | Clickjacking protection                    |
| X-Content-Type-Options        | ✗ MISSING | MIME sniffing protection                   |
| Referrer-Policy               | ✗ MISSING | Referrer leak prevention                   |
| Permissions-Policy            | ✗ MISSING | Browser feature restrictions               |

**Catatan:** Semua security headers hilang. Cloudflare handle rate limiting, tapi defense in depth header harus ditambah di origin (LiteSpeed config) atau via Cloudflare Transform Rules.

## 3. 🟢 Cookie Security Analysis (POSITIF)

**Bukti:**

```
curl -sI https://www.warmadewa.ac.id/ | grep "Set-Cookie"
```

**Cookies:**

| Cookie | Secure | HttpOnly | SameSite | Max-Age | Analisis |

|---|---|---|---|---|

| XSRF-TOKEN= ... | ✓ | ✗ | lax | 7200s (2h) | Laravel CSRF token (default flags) |

| laravel\_session= ... | ✓ | ✓ | lax | 7200s (2h) | Laravel session (default flags) |

| zesXZsnTWkKIShM7GTNeC6as5KHPUkywfN80QhYe= ... | ✓ | ✓ | lax | 7200s (2h) | **Custom cookie**

— perlu dicek |

**Positif:**

- ☒ **Secure** flag set (HTTPS only)
- ☒ **HttpOnly** set di session (XSS can't steal)
- ☒ **SameSite=Lax** (CSRF protection)
- ☒ Session timeout 2 jam (reasonable)

**Custom cookie concern:**

Cookie `zesXZsnTWkkISHm7GTNeC6as5KHPUkywfn80QhYe` tidak standard Laravel. Mungkin:

- Custom middleware auth
- Session encryption key
- Third-party service (analytics, ads, etc.)

**TIDAK ADA bukti ini vulnerable** dari static analysis, tapi IT Warmadewa sebaiknya verify:

- Apa cookie ini?
- Apakah value predictable?
- Apakah ada logout invalidation?

---

## 4. Form Analysis

**3 forms di homepage**, semua **search forms (GET)**:

- `<form action="https://www.warmadewa.ac.id/berita/search" method="GET">`
- 2 duplikat (search di header + di mobile)

**Analisis:**

- ☒ GET method (read-only, no state change)
- ☒ Tidak ada form login/auth di public surface
- ☒ Tidak ada input yang reflected di homepage

**Tidak ada XSS attack surface** dari forms yang visible.

---

## 5. Endpoint Reconnaissance

| Endpoint                   | Status | Catatan                               |
|----------------------------|--------|---------------------------------------|
| <code>/robots.txt</code>   | 200    | Normal                                |
| <code>/sitemap.xml</code>  | 404    | Tidak ada sitemap (atau di path lain) |
| <code>/wp-login.php</code> | 404    | Bukan WordPress (confirmed)           |
| <code>/wp-admin/</code>    | 404    | Bukan WordPress                       |
| <code>/wp-json/</code>     | 404    | Bukan WordPress                       |
| <code>/wp-content/</code>  | 404    | Bukan WordPress                       |

**Confirmed:** Bukan WordPress. Ini Laravel. Eliminates banyak common WP vulnerabilities (user enumeration, plugin exploits).

---

## 6. Other Observations

---

- ✓ Cloudflare di front (WAF + DDoS protection)
  - ✓ CSRF token visible (Laravel default)
  - ✓ Session cookie HttpOnly
  - ✓ 2-hour session timeout
  - ✓ HTTPS enforced (cookies `Secure` flag)
  - ✓ jQuery + Bootstrap (umum, well-known libraries)
  - ✓ Google Tag Manager (analytics — perlu privacy review terpisah)
  - ⚠ No security headers (defense in depth gap)
  - ⚠ LiteSpeed version not directly exposed (bagus, tapi bisa dicek via fingerprinting)
- 

## 7. Rekomendasi

---

### Immediate (1-2 jam)

1. **Tambah security headers** di LiteSpeed config atau Cloudflare Transform Rules:
  - `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload`
  - `Content-Security-Policy: default-src 'self'; ...`
  - `X-Frame-Options: SAMEORIGIN`
  - `X-Content-Type-Options: nosniff`
  - `Referrer-Policy: strict-origin-when-cross-origin`

### Short-term (1-2 minggu)

2. **Audit custom cookie** ( `zesXZsnTWkKIShM7GTNeC6as5KHPUkywfN80QhYe` ) — apa fungsi dan apakah secure
3. **Review Google Tag Manager** privacy implications (kalau EU user, GDPR concern)

### Medium-term (1-3 bulan)

4. Laravel security audit:
    - Update ke Laravel versi terbaru (kalau belum)
    - Check dependencies untuk known CVEs ( `composer audit` )
    - Review custom middleware
  5. HSTS preload submission
-

## 8. Yang TIDAK Saya Verifikasi (perlu dicek internal Warmadewa IT)

| Area                           | Yang perlu dicek                                             |
|--------------------------------|--------------------------------------------------------------|
| Laravel version & dependencies | <code>composer outdated</code> + <code>composer audit</code> |
| Custom cookie purpose          | Apakah predictable? Invalidation on logout?                  |
| Authenticated area             | Session handling setelah login                               |
| Admin panel                    | Authorization, brute force protection                        |
| Database credentials           | <code>.env</code> file security                              |
| CSRF on forms                  | Laravel biasanya handle, tapi verify custom forms            |
| File upload                    | Ada form upload? Validasi type?                              |
| API endpoints                  | Kalau ada API di <code>/api/</code>                          |
| Backup & logging               | Laravel.log security, file permissions                       |

## 9. Etika Pengujian

Saya hanya melakukan static analysis:

- ☒ HTTP header inspection
- ☒ HTML/JS source reading
- ☒ Public endpoint probing
- ☒ Tidak ada login attempt
- ☒ Tidak ada payload submission
- ☒ Tidak ada active testing

## 10. Kesimpulan

**Warmadewa secara keseluruhan lebih aman dari UNUD** yang aku review sebelumnya. Laravel framework memberikan:

- CSRF protection built-in
- Session management yang proper
- Cookie security default yang baik

**Gap utama: missing security headers.** Itu fix 1-2 jam via LiteSpeed config atau Cloudflare Transform Rules. Tidak ada exploitable hole dari public surface.

**Risk level:** ● **RENDAH** (defense in depth gap, bukan exploitable)

## 11. Kontak

---

### Afiq Andico

Mahasiswa Program Studi Sistem Informasi  
STIKOM Bali

- Email: [afiqandico13@gmail.com](mailto:afiqandico13@gmail.com)
- GitHub: [@afiqandico13](#)